

Threat Model Review Notes

ZavaX Oracle Threat Model



Scope

ZCG has requested that Least Authority perform a security audit of the ZavaX Oracle Threat Model written by the red-dev team. We completed the review and delivered the report on December 30, 2024. The engagement constituted our second security review of the ZavaX Oracle Threat Model and included a subsequent consultation session with the ZavaX Oracle team. Below, we present our observations.

The following is considered in scope for the consultation:

- Draft 2 of the ZavaX Oracle Threat Model:
<https://github.com/red-dev-inc/zavax-oracle/blob/leastauthority/security/threat-model.md>

Documentation & Resources

The following documentation and resources are available to the review team of Least Authority:

- Previous Review Report by Least Authority on the ZCG ZavaX Oracle Threat Model (PDF) *(delivered via email on 30 December, 2024)*
- Response to Least Authority ZavaX Oracle Threat Model Review Report (v 2025-12-30):
<https://docs.google.com/document/d/11654dOcMoqdXWqOriWLaK7BTuZmISTpOIky-nClhQuw/edit>

Areas of Concern

The following are areas of concern that will be investigated during the audit, along with any similar potential issues:

- Coverage and completeness: a general review for comprehensiveness;
- Logical and realistic technical details: a review of basic technical details and the security approach to support a rational implementation;
- Potential security issues: an assessment of the threat model and system design with a focus on data confidentiality and system integrity;
- Mechanisms and incentives: an analysis of token functions within the broader system and their interactions with various parties, including potential errors; and
- Anything else as identified during the initial analysis phase.

Recommendations

After reviewing the second version of the threat model, and holding a short consultation with the ZavaX Oracle team, our recommendations are as follows:

Extend ICTM by Defining Security Properties

We recommend that the ZavaX Oracle team consider expanding the use of Invariant-Centric Threat Modeling (ICTM) by including asset registry definitions, which specify the assets to be secured and the security properties that they should fulfill.

We recommend adding an Asset Registry that lists each asset with ID, name, description, and trust level (for example, node keys, admin credentials, appointment/removal process for A/B/C parties).

We additionally recommend listing security properties up front (for example, availability, authentication, integrity). Then, in each attack scenario, we advise explicitly referencing which properties are violated and which assets are impacted.

Our team suggests placing these sections at the beginning, after the participants and before the adversaries, to describe the system's assets and desired security properties before introducing adversaries. This structure allows direct referencing of affected security properties or assets during attack analysis.

Capture Colluding Adversaries

Our team suggests incorporating more examples of colluding adversaries in the threat model, extending cases where two or more adversaries act together and indicating how many colluders are required to break specific security properties. We also suggest adding a small matrix or table that maps adversary combinations to the violated properties.

Capture Adaptive Adversaries

Nodes and Red have different trust and impact levels. An adversary who initially gains a low-impact foothold can escalate to high-impact assets or act honestly to avoid detection until it becomes advantageous to flip. Our team recommends including scenarios with adaptive adversaries, who may gain information or capabilities mid-protocol and adjust their tactics before completion.

Consider All Cases of Red Compromise

Our team highlighted an inconsistency regarding the administrator, Red, where the threat model initially states that Red's compromise is not analyzed but then includes a usage case where Red is compromised. Our team added that Red should be included in the threat model since compromise is a realistic scenario.

We recommend including Red as an analyzable party, enumerating Red's assets and trust level in the Asset Registry, and analyzing the compromise of Red (although severe, it must be modeled). We additionally recommend avoiding partial treatment.

Add More Detail to Threat Model Mitigations for All Scenarios

Our team recommends that the ZavaX Oracle team add more detail to the threat model regarding mitigations. Specifically, the following four areas illustrate where the current mitigations are insufficiently developed:

- A majority of the nodes are compromised.**
 Mitigations are described vaguely in some usage scenarios. For example, if both Alice and Bob are compromised (that is, a majority), the process for identifying compromised nodes and initiating recovery is unclear. Similarly, the method by which a node regains control over its infrastructure after compromise via root access is not specified.
 We emphasize the need to define who identifies compromised nodes and how control is regained, clarifying that recovery might involve starting with fresh hardware rather than simply "regaining access."
- Distributed Denial-of-Service (DDoS) attack scenarios are underspecified.**
 When a node is subjected to a denial-of-service attack, the instruction to use hidden channels as a mitigation strategy is underspecified. We recommend defining concrete communication back-channels and clarifying assumptions (for example, whether attacks could congest the ISP, and if so, stating this explicitly).
 We also recommend providing a clear procedure for re-establishing communication during such attacks and considering a standby or emergency node that Red can appoint while the affected node is rebuilt.
- Web server redundancy and unpublished server usage lack clarity.**
 The ZavaX Oracle Threat Model mentions (a) community-run web servers and (b) an "unpublished" server (a hidden fallback endpoint) as mitigations for a DDoS on Walter's web server without listing the former as participants. This can lead to confusion over whether the threat model can rely solely on community-run web servers as a mitigation or whether it assumes an "unpublished" server is always available. We recommend addressing this ambiguity as follows:
 - Clarifying availability dependency** by stating whether the model relies on scale (many public endpoints with DDoS protection), on a hidden fallback that remains off attackers' radars, or on both.
 - Specifying promotion and rotation** procedures if the unpublished server is revealed (for example, during an attack), including whether a new unpublished server is created and how its secrecy is maintained.
 - Defining trust and access control** by identifying who can access the unpublished server and describing how risks of doxxing, insider leaks, or traffic analysis are mitigated.
 - Outlining mitigation boundaries** by defining which attacks each approach addresses (for example, volumetric DDoS, targeted blocking, BGP hijack, takedown/censorship), and which remain out of scope.
- Tie Scenarios to assets and properties**
 - For each attack, we recommend referencing the relevant asset IDs and impacted security properties, and noting whether collusion or adaptation alters the outcome. This will improve clarity for stakeholders and auditors.

Clarify Adversary Detection

- Compromised nodes (for example, by Mallory via root access) can choose to act "honestly" when replying to Walter to avoid detection.
 We recommend naming the actor responsible for detection and triage in each scenario (For example, Red, a specific monitoring service, or the community).
- If community reports are relied upon, we recommend stating that Red is the verifier and final arbiter, with the ability to independently validate through on-chain truth.

- We also recommend clarifying the party responsible for detecting malicious actors.

Correct Typographical Errors

- [This](#) usage scenario describes Alice and Bob as controlling nodes 2 and 3, even though they control nodes 1 and 2. We recommend correcting the scenario to accurately reflect that Alice and Bob control nodes 1 and 2.

Consulting Team

Anna Kaplan, Cryptography Researcher and Engineer

Anna is a mathematician and cryptographer, with experience working at Zcash Foundation and IBM Research. Besides being interested in new cryptographic advancements, she is also very passionate about communicating all things cryptography and privacy.

Miguel Quaresma, Security Researcher and Engineer

Miguel is a cryptography and security researcher with experience in cryptographic engineering and applied formal methods, currently pursuing his PhD at the Max Planck Institute for Security and Privacy. Previously, he worked as a cybersecurity analyst in the financial industry, where he was responsible for penetration tests and security analysis of infrastructures and applications.

About Least Authority

We believe that people have a fundamental right to privacy and that the use of secure solutions enables people to more freely use the Internet and other connected technologies. We provide security consulting services to help others make their solutions more resistant to unauthorized access to data and unintended manipulation of the system. We support teams from the design phase through the production launch and after.

The Least Authority team has skills for reviewing code in multiple Languages, such as C, C++, Python, Haskell, Rust, Node.js, Solidity, Go, JavaScript, Zokrates, and circom, for common security vulnerabilities and specific attack vectors. The team has reviewed implementations of cryptographic protocols and distributed system architecture in cryptocurrency, blockchains, payments, smart contracts, zero-knowledge protocols, and consensus protocols. Additionally, the team can utilize various tools to scan code and networks and build custom tools as necessary.

Least Authority was formed in 2011 to create and further empower freedom-compatible technologies. We moved the company to Berlin in 2016 and continue to expand our efforts. We are an international team that believes we can have a significant impact on the world by being transparent and open about the work we do.

For more information about our security consulting, please visit <https://leastauthority.com/security-consulting/>.